Nhill website — deployment and database

Version française : README.md

This folder holds the public Nhill website and the small service that receives its forms (demo, pilot programme, partnership, contact). It is **separate** from the Nhill application: different database, different roles, different secrets. A breach of the website gives no access to the shops' data.

Item	Location	Purpose
Generated pages	`index.html`, `pages/`, `en/`, `404.html`, `sitemap.xml`, `robots.txt`	static HTML served as is
Page sources	`src/pages/fr/*.html`, `src/pages/en/*.html`	content; regenerate with `tools/build_site.py`
Styles, script, images	`assets/`	CSS3, dependency-free JavaScript, WebP, local fonts
Public configuration	`config/site.json`	three public values only (see § 3)
Form backend	`backend/`	standard Python 3 (+ psycopg 3 for PostgreSQL)
Deployment	`backend/deploy/`	systemd unit, daily purge, Caddyfile snippet
Tools	`tools/`	generation, checks, public configuration

1. Security model

- The browser **never** sees the database address or password. The JavaScript posts the form as JSON to `SITE_API_BASE_URL/api/forms/<kind>`; only the backend, on the server, connects to the database.
- The backend listens on `127.0.0.1:8090`; only the TLS proxy (Caddy) is exposed.
- The database role used by the web service can **insert** submissions but cannot read, change or delete them. A compromised service therefore cannot exfiltrate the submissions already received. Reading, export and erasure go through the maintenance command, with another role.
- Form protections: validation in the browser **and** on the server, origin allow-list (CORS), mandatory `application/json`, 16 KB body limit, honeypot field, minimum filling time, limit per IP address and per form (5/hour by default) and a global daily limit (300), control characters removed, explicit consent to the privacy policy, separate marketing consent unticked by default.
- Minimisation: only the fields of the form concerned are kept; the IP address is never stored, only an HMAC fingerprint (key `SITE_IP_HASH_SALT`) cleared after 30 days; submissions are deleted after 365 days (daily purge).
- Service logs contain neither IP addresses nor form content.

These measures reduce risk; they do not make the service invulnerable. Keep the system and Python up to date, and go through § 9.

2. Quick start for development (SQLite)

```
cd website/backend
export SITE_IP_HASH_SALT="$(openssl rand -hex 32)"
export SITE_ALLOWED_ORIGINS=http://localhost:8000
export SITE_SQLITE_PATH=./data/site.sqlite3          # folder ignored by git
python3 -m nhill_site.cli init
python3 -m nhill_site.server &                        # http://127.0.0.1:8090
cd .. && SITE_API_BASE_URL=http://127.0.0.1:8090 python3 tools/configure_site.py
python3 -m http.server 8000                           # http://localhost:8000
```

Restore `config/site.json` to its committed state before committing (`git checkout website/config/site.json`).

Tests: `cd website/backend && python3 -m unittest discover -s tests -v` (13 tests, throwaway SQLite database). Page checks: `python3 website/tools/check_site.py website`.

3. Configuration variables

3.1 Public configuration (`config/site.json`, downloaded by every visitor)

Deployment variable	JSON key	Example	Effect
`SITE_PUBLIC_BASE_URL`	`publicBaseUrl`	`https://www.example.cd`	canonical tags, hreflang, sitemap
`SITE_API_BASE_URL`	`apiBaseUrl`	`https://www.example.cd`	backend address; empty = forms say “not connected”
`SITE_CONTACT_EMAIL`	`contactEmail`	`contact@example.cd`	address shown when forms are not connected

`python3 website/tools/configure_site.py` writes these three values from the environment and refuses any other key, any non-`https://` address (except `localhost`) and any credentials inside a URL. After changing `SITE_PUBLIC_BASE_URL`, regenerate the pages: `python3 website/tools/build_site.py`.

3.2 Backend configuration (file `/etc/nhill-site/site.env`, never public)

Full template: `backend/.env.example` (dummy values only).

Variable	Default	Description
`SITE_DATABASE_ENGINE`	`sqlite`	`sqlite` or `postgresql`
`SITE_SQLITE_PATH`	`data/site.sqlite3`	SQLite file (created with mode 600, folder 700)
`SITE_DATABASE_HOST`	`127.0.0.1`	PostgreSQL host
`SITE_DATABASE_PORT`	`5432`	PostgreSQL port
`SITE_DATABASE_NAME`	`nhill_site`	database dedicated to the website
`SITE_DATABASE_USER`	`nhill_site_app`	web service role (insert only)
`SITE_DATABASE_PASSWORD`	*(none)*	required with PostgreSQL
`SITE_DATABASE_SSLMODE`	`prefer`	`disable`, `prefer`, `require`, `verify-full`

Variable	Default	Description
`SITE_MAINTENANCE_DATABASE_USER` / `_PASSWORD`	—	role of the maintenance command
`SITE_LISTEN_HOST` / `SITE_LISTEN_PORT`	`127.0.0.1` / `8090`	service listen address
`SITE_ALLOWED_ORIGINS`	*(none)*	allowed origins, comma-separated; required
`SITE_TRUST_PROXY`	`0`	`1` behind Caddy: uses the rightmost `X-Forwarded-For` entry
`SITE_IP_HASH_SALT`	*(none)*	≥ 32 characters, `openssl rand -hex 32`; required
`SITE_RETENTION_DAYS`	`365`	submission retention
`SITE_IP_RETENTION_DAYS`	`30`	IP fingerprint retention
`SITE_MIN_FILL_MS`	`3000`	minimum filling time (anti-bot)
`SITE_RATE_PER_HOUR`	`5`	submissions per IP, per form, per hour
`SITE_RATE_PER_DAY_GLOBAL`	`300`	submissions per day, all visitors
`SITE_PUBLIC_BASE_URL`, `SITE_CONTACT_EMAIL`	—	information, same as § 3.1
`SITE_NOTIFY_EMAIL`, `SITE_SMTP_HOST/PORT/USER/PASSWORD/FROM`	—	optional notification (kind and identifier only, never the content)
`SITE_ENV_FILE`	—	variables file to load (refused if readable by anyone but its owner)

The service refuses to start if a required value is missing or too weak.

4. Dedicated PostgreSQL database

SQLite is enough for a low-traffic website on a single server. PostgreSQL is recommended when the database is on another machine, when several instances run, or when your backups are already organised around PostgreSQL. Tested with PostgreSQL 16 (locally and in CI); the schema uses nothing specific to a recent version.

4.1 Create the database and roles (once, as superuser)

```
sudo apt install postgresql python3-psycopg
cd website/backend/schema/postgresql
OWNER_PW="$(openssl rand -base64 30)"; APP_PW="$(openssl rand -base64 30)";
MAINT_PW="$(openssl rand -base64 30)"
sudo -u postgres psql -v ON_ERROR_STOP=1 \
     -v owner_pw="$OWNER_PW" -v app_pw="$APP_PW" -v maint_pw="$MAINT_PW" -f 000_roles.sql
```

Store the three passwords in your secrets vault; never write them into a versioned file. `000_roles.sql` creates:

Role	Privileges	Used by
`nhill_site_owner`	owner of the database and of schema `site`	migrations only
`nhill_site_app`	`CONNECT`; `INSERT` on `submissions`; `SELECT, INSERT, UPDATE` on `rate_limits`	web service

Role	Privileges	Used by
`nhill_site_maint`	`CONNECT`; `SELECT, UPDATE, DELETE` on `submissions`; `SELECT, DELETE` on `rate_limits`	maintenance command, purge

`PUBLIC` loses its rights on the database and on schema `public`.

4.2 Apply the schema (migrations)

```
PGPASSWORD="$OWNER_PW" psql "host=127.0.0.1 dbname=nhill_site user=nhill_site_owner
sslmode=require" \
     -v ON_ERROR_STOP=1 -f 001_init.sql
```

Files `schema/postgresql/NNN_*.sql` are applied in order, once, with the owner role. A future migration will be a new `002_…sql` file; a file already applied in production is never edited. `001_init.sql` is idempotent (`IF NOT EXISTS`) and transactional.

4.3 Configure and test the connection

In `/etc/nhill-site/site.env`:

```
SITE_DATABASE_ENGINE=postgresql
SITE_DATABASE_HOST=127.0.0.1
SITE_DATABASE_PORT=5432
SITE_DATABASE_NAME=nhill_site
SITE_DATABASE_USER=nhill_site_app
SITE_DATABASE_PASSWORD=<APP_PW>
SITE_DATABASE_SSLMODE=require
SITE_MAINTENANCE_DATABASE_USER=nhill_site_maint
SITE_MAINTENANCE_DATABASE_PASSWORD=<MAINT_PW>
```

```
sudo -u nhill-site env SITE_ENV_FILE=/etc/nhill-site/site.env python3 -m nhill_site.cli check
# → connexion OK (postgresql), 0 demande(s) enregistrée(s)
curl -s http://127.0.0.1:8090/api/health        # → {"status": "ok"}
```

Privilege check (must fail with “permission denied”):

```
PGPASSWORD="$APP_PW" psql "host=127.0.0.1 dbname=nhill_site user=nhill_site_app" -c 'SELECT *
FROM submissions'
```

4.4 TLS to the database

- Database on the same machine: local connection, `sslmode=prefer` is acceptable.
- Database on another machine: `sslmode=verify-full` with the CA certificate in `~nhill-site/.postgresql/root.crt` (or `PGSSLROOTCERT`), and in `pg_hba.conf` a rule `hostssl nhill_site nhill_site_app <web-server-ip>/32 scram-sha-256`. Do not open port 5432 to the Internet.

4.5 Backup and restore

```
# daily encrypted backup (example)
pg_dump -Fc "host=127.0.0.1 dbname=nhill_site user=nhill_site_owner" \
  | gpg --encrypt --recipient <key> > nhill_site-$(date +%F).dump.gpg
# restore into an empty database created by 000_roles.sql
gpg --decrypt nhill_site-YYYY-MM-DD.dump.gpg \
  | pg_restore --no-owner --role=nhill_site_owner -d "host=127.0.0.1 dbname=nhill_site
user=nhill_site_owner"
```

SQLite: `sqlite3 /var/lib/nhill-site/site.sqlite3 ".backup '/backups/site-$(date +%F).sqlite3'"` then encrypt the file. Backups hold personal data: same retention as the database (365 days), restricted access. Test a restore at least once a quarter.

4.6 Credential rotation

1. `ALTER ROLE nhill_site_app PASSWORD '<new>';` (as superuser or owner);
2. update `SITE_DATABASE_PASSWORD` in `/etc/nhill-site/site.env`;
3. `sudo systemctl restart nhill-site`, then `python3 -m nhill_site.cli check`.

Same for `nhill_site_maint`. Also change `SITE_IP_HASH_SALT` after a suspected leak (consequence: rate-limit counters start from zero). Rotate immediately if a secret may have been exposed (log, screenshot, git repository).

5. Production deployment (Debian 12/13, Ubuntu 22.04/24.04)

```
sudo useradd --system --home /var/lib/nhill-site --shell /usr/sbin/nologin nhill-site
sudo install -d -o nhill-site -g nhill-site -m 700 /var/lib/nhill-site
sudo install -d -m 750 -g nhill-site /etc/nhill-site
sudo install -m 600 -o nhill-site -g nhill-site website/backend/.env.example /etc/nhill-
site/site.env   # then edit
sudo cp -r website/backend /opt/nhill-site
sudo cp website/backend/deploy/nhill-site*.service website/backend/deploy/nhill-site-
purge.timer /etc/systemd/system/
sudo systemctl daemon-reload
sudo systemctl enable --now nhill-site nhill-site-purge.timer
# static website
SITE_PUBLIC_BASE_URL=https://www.example.cd SITE_API_BASE_URL=https://www.example.cd \
SITE_CONTACT_EMAIL=contact@example.cd python3 website/tools/configure_site.py
python3 website/tools/build_site.py
sudo install -d /var/www/nhill-site
sudo rsync -a --delete --exclude backend --exclude src --exclude tools --exclude 'README*'
website/ /var/www/nhill-site/
# TLS proxy: set the domain name in the snippet, then import it from /etc/caddy/Caddyfile
sudo cp website/backend/deploy/Caddyfile.site /etc/caddy/nhill-site.caddy
```

The Caddy snippet serves the site, forwards `/api/*` to the backend, adds HSTS and a strict Content Security Policy, and refuses source or configuration files. `scripts/build-website.sh` produces `dist/website/nhill-website-<version>.tar.gz` (without `.env` or database) with its SHA-256 sums.

Development vs production

	Development	Production
Database	SQLite in `website/backend/data/`	SQLite in `/var/lib/nhill-site/` or dedicated PostgreSQL
Origins	`http://localhost:8000`	`https://www.<domain>` only
`SITE_TRUST_PROXY`	`0`	`1` (behind Caddy)
TLS	none	Caddy (automatic certificate), `sslmode=require` or `verify-full`
Secrets	terminal variables	`/etc/nhill-site/site.env` (600, owner `nhill-site`) or a secrets manager

6. Handling submissions

```
cd /opt/nhill-site
alias site-cli='sudo -u nhill-site env SITE_ENV_FILE=/etc/nhill-site/site.env python3 -m
nhill_site.cli'
site-cli stats                       # count per form and status
site-cli list --kind pilot           # list (without the message)
site-cli show <id>                   # details
site-cli set-status <id> contacted   # new, contacted, qualified, closed
site-cli export --email x@y.cd       # a person's access request (JSON)
site-cli delete --email x@y.cd       # erasure request
site-cli unsubscribe --email x@y.cd  # withdraw marketing consent
site-cli purge                       # retention (run daily by the timer)
```

Answer access and erasure requests within the time limits stated in the privacy policy; keep a record of the answer. The command messages are in French.

7. Automatic checks

- `website/tools/check_site.py`: internal links, `alt`, titles, descriptions, `lang`, FR/EN pairs, no secret patterns in public files.
- `website/tools/build_site.py --check`: generated pages match their sources.
- Backend tests on SQLite (local, CI) and on PostgreSQL 16 with the real roles (job `site-backend-postgresql` in `.github/workflows/docs-website.yml`).

8. Troubleshooting

Symptom	Likely cause	Action
Form: “This form is not connected to our server yet”	empty `apiBaseUrl`	`configure_site.py` with `SITE_API_BASE_URL`, redeploy `config/site.json`
403 response	origin missing from `SITE_ALLOWED_ORIGINS`	add the exact origin (scheme + host, no trailing `/`)
429 response	limit reached	wait (`Retry-After`); adjust `SITE_RATE_PER_HOUR` carefully

Symptom	Likely cause	Action
422 response	invalid field (name in `field`)	fix the input
Every visitor blocked together behind Caddy	`SITE_TRUST_PROXY=0`: the IP seen is the proxy's	`SITE_TRUST_PROXY=1`
`psycopg 3 absent`	missing package	`sudo apt install python3-psycopg`
`password authentication failed`	password or `pg_hba.conf`	check the environment file and the `scram-sha-256` rule
`permission denied for table submissions` in the service	normal for a read; abnormal for an insert	re-apply `001_init.sql` (grants)
`SITE_IP_HASH_SALT doit contenir au moins 32 caractères`	missing or short value	`openssl rand -hex 32`
`journalctl -u nhill-site` empty after an error	service not started	`systemctl status nhill-site`

9. Before opening the forms to the public

- ☐ Privacy policy and legal notice completed (publisher identity, contact, host) and reviewed by a lawyer — see `legal/`.
- ☐ Formalities with the DRC data protection authority checked (see `docs/en/legal-parameters.md`).
- ☐ `SITE_IP_HASH_SALT` and passwords generated for this server, stored in a vault.
- ☐ Encrypted backup and restore tested.
- ☐ Test submission of each form, then `cli delete` of those tests.
- ☐ A named person reads the submissions and answers them.